

Lab -6 - Metasploit Exploit Framework (MSF) - Remote Exploits

Q2 – Network device

Ans -

The Target lies somewhere in 192.168.1.1 - 192.168.1.254. This time use "ip route show" and find out the device name on your machine which would be used to handle packets going to target 2. You can identify it by looking at the output, finding the line involved with the target subnet, and looking for the "dev".

In a new terminal window, use tcpdump to monitor the network traffic on this interface while carrying out the lab.

Target network device:

Check Tests: Complete
Gateway IP PASS

What is your machine's IP number on the target network?

Your IP:

Check Tests: Complete
Local IP PASS

```
kali@host-3-89: ~  
File Actions Edit View Help  
(kali@host-3-89)-[~]  
$ ip route show  
default via 10.0.3.94 dev eth0 proto dhcp src 10.0.3.89 metric 100  
10.0.3.88/29 dev eth0 proto kernel scope link src 10.0.3.89 metric 100  
192.168.1.0/24 dev labbr0 proto kernel scope link src 192.168.1.254  
(kali@host-3-89)-[~]  
$
```

Q3- Network scanning with nmap

Use nmap to sweep the target network, and identify the IP address of the target machine. Use the appropriate flags to keep this scan efficient.

Target IP:

Check Tests: Complete

target ip PASS

After discovering a target system, we want to identify which OS it might be running. From Kali using nmap, perform an OS Fingerprint Scan on the TARGET machine, with no name resolution and no host discovery. Take note of the OS and possible Service packs. List the first 3 open ports found in numerical order.

Open port 1
Open port 2
Open port 3

```
(kali@host-3-89)-[~]
$ nmap -n -sn 192.168.1.1-254
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 11:49 GMT
Nmap scan report for 192.168.1.2
Host is up (0.0037s latency).
MAC Address: 00:0C:B1:00:07:90 (Salland Engineering (Europe) BV)
Nmap scan report for 192.168.1.254
Host is up.
Nmap done: 254 IP addresses (2 hosts up) scanned in 1.97 seconds
```

```
(kali@host-3-89)-[~]
$
```

```
(kali@host-3-89)-[~]
$ nmap -n -O 192.168.1.1-254
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-11 11:52 GMT
Nmap scan report for 192.168.1.2
Host is up (0.0045s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 00:0C:B1:00:07:90 (Salland Engineering (Europe) BV)
Device type: general purpose
Running: Microsoft Windows XP|2003
OS CPE: cpe:/o:microsoft:windows_xp::sp3:embedded cpe:/o:microsoft:windows_xp::sp
2 cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_server_2003
OS details: Microsoft Windows XP SP2 or SP3, or Windows Embedded Standard 2009, M
icrosoft Windows XP SP2 or SP3, or Windows Server 2003
Network Distance: 1 hop
```

Q4 MetaSploit Framework – Strat MSF database and console

```
msf6 >
```

```
VULNERABLE:
Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
State: VULNERABLE
IDs: CVE:CVE-2017-0143
Risk factor: HIGH
  A critical remote code execution vulnerability exists in Microsoft SMBv1
  servers (ms17-010).

Disclosure date: 2017-03-14
References:
  https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
  https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
  samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
```

We would typically now perform a vulnerability scan against our target using a full blown scanner such as OpenVAS.

As Windows SMB services are running we could perform a quick assessment using the nmap NSE Scripts under the category vulns, which checks for some of the most well know vulnerabilities.

Note: Some of the scripts are marked as intrusive and unsafe, which means they could crash the target system, so would not be used in a production environment.

Documentation of the Nmap SMB Vulnerability scanning Scripts under vuln: <https://nmap.org/nsedoc/categories/vuln.html>

```
nmap --script vuln 192.168.1.x
```

Note if the target fails during the test, go to the bottom of the tutorial and click the button to stop the target, then go to the top of the tutorial and use the buttons to restart and test the target.

Which SMB vulnerability found was assigned a CVE in 2017?

CVE issue in 2017 identified CVE-2017-0143

Check Tests: Complete
2017 CVE PASS

Which directory holds the built in vulnerability scanners? - auxiliary/scanner

```
(kali@host-3-89)-[/usr/share/metasploit-framework/modules/auxiliary]  
$ ls  
admin      bnat      cloud     docx      example.py fileformat gather  pdf      server  spoof  
analyze    client    crawler   dos       example.rb fuzzers  parser  scanner  sniffer  sqli
```

How are exploits sorted? **By Target's OS**

Where might exploits that work on several different OS's be stored?

Multi

```
(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits]  
$ ls  
aix          dialup      firefox     mainframe  qnx  
android     example_linux_priv_esc.rb freebsd     multi      solaris  
apple_ios   example.py  hpx         netware    unix  
bsd         example.rb  irix        openbsd    windows  
bsdi        example_webapp.rb linux       osx  
  
(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits]  
$ cd multi  
  
(kali@host-3-89)-[/usr/.../metasploit-framework/modules/exploits/multi]  
$ ls  
browser      gdb         ids         misc        postgres    scada       upnp        wyse  
elasticsearch hams       iiop        mysql       realserver  script      veritas  
fileformat   handler.rb kubernetes  ntp         samba       ssh         vnc  
ftp          http       local       php         sap         svn         vpn
```

How are the windows exploits categorised?

By target application

```
(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits]
$ cd windows

(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits/windows]
$ ls
antivirus  email      ibm        lotus      nfs        postgres  smtp       vpn
arkeia    emc        iis        lpd        nimsoft    proxy     ssh        winrm
backdoor   fileformat imap       misc       nntp       rdp       ssl        wins
backupexec firewall  isapi     mmsp       novell     sage      telnet
brightstor ftp       ldap      mmsql      nuuo       scada     tftp
browser    games     license   mssql      oracle     sip       unicenter
dcerpc     http      local     mysql      pop3       smb       vnc
```

To check the particular CVE details of any Vulnerability MS of Ruby exploit script “rb”

inside **smb** using **windows** directory:

cd smb

less MSxx-xxx

check CVE

```
%w(CVE 2008-4250),
```

Command -

```
(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits/windows]
$ cd smb

(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits/windows/smb]
$ ls
cve_2020_0796_smbghost.rb  ms08_067_netapi.rb
generic_smb_dll_injection.rb  ms09_050_smb2_negotiate_func_index.rb
group_policy_startup.rb      ms10_046_shortcut_icon_dllloader.rb
ipass_pipe_exec.rb          ms10_061_spoolss.rb
ms03_049_netapi.rb          ms15_020_shortcut_icon_dllloader.rb
ms04_007_killbill.rb        ms17_010_eternalblue.rb
ms04_011_lsass.rb           ms17_010_psexec.rb
ms04_031_netdde.rb          netidentity_xtierpcpipe.rb
ms05_039_pnp.rb             psexec.rb
ms06_025_rasmans_reg.rb     smb_deliver.rb
ms06_025_rras.rb            smb_doublepulsar_rce.rb
ms06_040_netapi.rb          smb_relay.rb
ms06_066_nwapi.rb           smb_rras_erraticgopher.rb
ms06_066_nwwks.rb           smb_shadow.rb
ms06_070_wkssvc.rb          timbuktu_plughntcommand_bof.rb
ms07_029_msdns_zonename.rb  webexec.rb

(kali@host-3-89)-[/usr/share/metasploit-framework/modules/exploits/windows/smb]
$ less ms08_067_netapi.rb

zsh: suspended  less ms08_067_netapi.rb
```

To check the EDB-ID – click on the title of the MS or CVE entries.

The screenshot shows the Exploit Database website with a search for 'MS08-067'. The results table lists several exploits, with the last one, 'Microsoft Windows Server - Code Execution (PoC) (MS08-067)' by 'stephen lawler', highlighted with a blue border.

Date	D	A	V	Title	Type	Platform	Author
2016-02-26	↓	×		Microsoft Windows - 'NetAPI32.dll' Code Execution (Python) (MS08-067)	Remote	Windows	ohnozzy
2011-01-21	↓	✓		Microsoft Windows Server - Service Relative Path Stack Corruption (MS08-067) (Metasploit)	Remote	Windows	Metasploit
2008-11-16	↓	✓		Microsoft Windows Server 2000/2003 - Code Execution (MS08-067)	Remote	Windows	Debasis Mohanty
2008-11-12	↓	✓		Microsoft Windows Server - Code Execution (MS08-067)	Remote	Windows	Polymorphours
2008-10-26	↓	✓		Microsoft Windows Server - Universal Code Execution (MS08-067)	Remote	Windows	EMM
2008-10-23	↓	✓		Microsoft Windows Server - Code Execution (PoC) (MS08-067)	DoS	Windows	stephen lawler

Showing 1 to 6 of 6 entries (filtered from 46,496 total entries)

Pagination: FIRST PREVIOUS 1 NEXT LAST

To create a new user on the target -
payload – adduser.rb

To create a tcp listener on the port and bind a shell
payload – shell_bind_tcp.rb

```
(kali@host-3-89)-[/usr/.../metasploit-framework/modules/payloads/singles]
$ cd windows

(kali@host-3-89)-[/usr/.../modules/payloads/singles/windows]
$ ls
adduser.rb                                metsvc_bind_tcp.rb
dns_txt_query_exec.rb                    metsvc_reverse_tcp.rb
download_exec.rb                         pingback_bind_tcp.rb
encrypted_shell_reverse_tcp.rb           pingback_reverse_tcp.rb
exec.rb                                  powershell_bind_tcp.rb
format_all_drives.rb                     powershell_reverse_tcp.rb
loadlibrary.rb                           powershell_reverse_tcp_ssl.rb
messagebox.rb                             shell_bind_tcp.rb
meterpreter_bind_named_pipe.rb            shell_bind_tcp_xpfw.rb
meterpreter_bind_tcp.rb                   shell_hidden_bind_tcp.rb
meterpreter_reverse_http.rb               shell_reverse_tcp.rb
meterpreter_reverse_https.rb              speak_pwned.rb
meterpreter_reverse_ipv6_tcp.rb           x64
meterpreter_reverse_tcp.rb
```

Which windows command is executed on the target machine to create a new user?

Cmd.exe /c net user

```

if not cust.empty?
  print status("Using custom group name #{cust}")
  return "cmd.exe /c net user #{user} #{pass} /ADD && " +
    "net localgroup \"#{cust}\" #{user} /ADD"

```

To examine the shell_bind_tcp.rb script and review the payload itself.
 less shell_bind_tcp.rb

Shellcode bytes - 328

```

# This module requires Metasploit: https://metasploit.com/download
# Current source: https://github.com/rapid7/metasploit-framework
##

module MetasploitModule
  CachedSize = 328

```

Q5 – Metasploit Framework – msfconsole

Version - v6.4.38-dev

To get count – show exploits | wc -l
 -- show payloads |wc -l

Search command can help us find useful exploits.
 search -h

To get list only the windows smb exploits:

Search type:exploit name:smb

To get specific year – use disclosure

Search type:exploit name:smb disclosure:YEAR

```

msf6 > search type:exploit name:smb disclosure_date:2020
Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/windows/local/cve_2020_0796_smbghost 2020-03-13      good  Yes    SMBv3 Compression Buffer Overflow
1  \_ AKA: SMBGhost                          .               .      .      .
2  \_ AKA: CoronaBlue                        .               .      .      .
3  exploit/windows/smb/cve_2020_0796_smbghost 2020-03-13      average Yes    SMBv3 Compression Buffer Overflow
4  \_ AKA: SMBGhost                          .               .      .      .
5  \_ AKA: CoronaBlue                        .               .      .      .

Interact with a module by name or index. For example info 5, use 5 or use exploit/windows/smb/cve_2020_0796_smbghost
msf6 >

```

added modules in 2020 - 2

exploit module file name – cve_2020_0796_smbghost

Type of memory - bufferflow

exploit – **remote**